TRƯỜNG ĐẠI HỌC KHOA HỌC TỰ NHIÊN TP.HCM
KHOA CÔNG NGHỆ THÔNG TIN - NGÀNH HỆ THỐNG THÔNG TIN

ỨNG DỤNG MÔ HÌNH KIỂM SOÁT TRUY CẬP CHO OUTSOURCED STORAGE

(*Ciphertext-Policy Attribute-Based Encryption*)

An toàn và bảo mật trong hệ thống thông tin — HP3-K35

GVHD: PGS.TS. Đặng Trần Khánh

GV Trợ giảng: TS. Phạm Thị Bạch Huệ · ThS. Lương Vĩ Minh

NHÓM 06

Nguyễn Võ Thiên Hà	**25C12020**
Nguyễn Gia Hân	**25C12021**
Trần Nhật Trường	**25C12014**
Trương Trung Vĩnh	**25C12015**

NỘI DUNG TRÌNH BÀY

Agenda

1 **Đặt vấn đề & Hướng tiếp cận**
Vì sao cách bảo mật cũ không đủ, CP-ABE giải quyết ra sao, mục tiêu của nhóm

2 **Threat Model**
Xác định bên tin cậy và bên không tin cậy trong hệ thống

3 **Phân tích và thiết kế hệ thống**
Trọng tâm: chính sách, cây truy cập, kiến trúc và luồng xử lý

4 **Kiểm chứng & Kết luận**
Kịch bản tấn công, tính đúng đắn, và hướng phát triển tiếp theo

Đưa dữ liệu lên outsourced storage, nhưng ai mới thực sự kiểm soát?

1 Bảo mật dữ liệu dựa vào đâu?

Phân quyền trong DBMS, mã hóa khi lưu trữ (TDE), kiểm soát truy cập ở tầng ứng dụng. Điểm chung: tất cả đều giả định môi trường vận hành là đáng tin.

↓

2 Giả định đó sụp đổ khi outsource lên cloud

Nhà cung cấp có toàn quyền admin: đọc thẳng file dữ liệu, nắm cả khóa TDE, bỏ qua phân quyền DBMS, truy cập được bản sao lưu, khả năng cấu hình sai, ... Mọi lớp bảo vệ ở bước 1 đều vô hiệu.

↓

3 Câu hỏi đặt ra cho đồ án

Làm sao một tổ chức vẫn bảo vệ được dữ liệu của mình, ngay cả khi bên thứ ba nắm toàn quyền quản trị hệ thống?



HƯỚNG ĐI CỦA ĐỒ ÁN

Thay vì tiếp tục tin tưởng người vận hành, gắn quyền truy cập trực tiếp vào phép mã hóa: cloud chỉ giữ được bản mã, không có khóa thuộc tính phù hợp thì dữ liệu là vô nghĩa.

Ciphertext-Policy Attribute-Based Encryption: khái niệm cốt lõi

Định nghĩa: CP-ABE là một dạng mã hóa công khai mở rộng, trong đó bản mã được gắn với một Access Policy viết trên các thuộc tính, còn khóa bí mật của người dùng gắn với tập thuộc tính họ sở hữu. Giải mã chỉ thành công khi tập thuộc tính đó thỏa policy.

BA THÀNH PHẦN CHÍNH



Attribute (thuộc tính)

Đặc điểm định danh người dùng: vai trò, khoa/bộ phận, cấp bậc...



Access Policy (chính sách)

Biểu thức AND/OR trên thuộc tính, gắn vào bản mã ngay lúc mã hóa.



Public Key / Master Key

PK dùng để mã hóa công khai; MasterKey do Key Authority giữ để cấp SecretKey.

BỐN THUẬT TOÁN CỐT LÕI

`Setup()`

Khởi tạo tham số hệ thống — sinh Public Key & Master Key.

`KeyGen()`

Cấp Secret Key cho user, gắn theo tập thuộc tính của họ.

`Encrypt()`

Mã hóa dữ liệu, gắn kèm Access Policy do Data Owner chọn.

`Decrypt()`

Giải mã cục bộ — thành công nếu thuộc tính thỏa Access Policy.

So sánh CP-ABE với các mô hình kiểm soát truy cập khác

Tiêu chí	DAC/MAC	RBAC	ABAC	KP-ABE	CP-ABE
Nơi thực thi quyền	OS/DBMS	DBMS/ứng dụng	DBMS/ứng dụng	Mã hóa (client)	**Mã hóa (client)**
Thành phần phải tin	OS+DBMS+host	DBMS+host	DBMS+host	Key Authority	**Key Authority**
Chống host xâm nhập	Không	Không	Không	Có	**Có**
Ai quyết định policy khi mã hóa?	Chủ sở hữu file	Admin (vai trò)	Admin (quy tắc)	Bên cấp khóa	**Data Owner**
Độ chi tiết chính sách	Thấp	Cố định	Linh hoạt	Gắn ở khóa	**Gắn ở mã hóa**
Chi phí thu hồi quyền	Thấp	Thấp	Trung bình	Cao	**Cao**

Vì sao chọn CP-ABE: đây là mô hình cho phép Data Owner (chủ sở hữu dữ liệu) thực thi quyền bằng mã hóa, vừa tự mình quyết định chính sách đó mà không phải giao phó cho admin hay bất kỳ bên thứ ba nào.

Tài liệu tham khảo: [1] Sahai & Waters (2005) — ABE · [2] Bethencourt, Sahai & Waters (2007) — CP-ABE · [3] Popa et al. — CryptDB (2011) · [4] Li et al. — PHR (2013) · [5] Yu et al.; Hur & Noh (2010–2011) — Attribute retrieval.

Đồ án hướng đến điều gì, và cần trả lời câu hỏi nào

MỤC TIÊU

1. Phân tích giới hạn của RBAC/DAC/MAC khi bản thân storage host không đáng tin.
2. Thiết kế kiến trúc kiểm soát truy cập thực thi bằng mã hóa,.
3. Định nghĩa mô hình chính sách ánh xạ vai trò/thuộc tính (dựa trên ABAC) sang chính sách mã hóa.
4. Xây dựng sơ đồ kiến trúc: mã hóa, giải mã, quản lý khóa và thu hồi khóa.

CÂU HỎI NGHIÊN CỨU

RQ1

Ánh xạ RBAC/ABAC hiện có sang chính sách mã hóa CP-ABE mà không mất ngữ nghĩa nghiệp vụ?

RQ2

Kiến trúc nào cho phép thu hồi quyền hiệu quả mà không phải mã hóa lại toàn bộ dữ liệu?

RQ3

Đánh đổi giữa độ mịn chính sách và chi phí tính toán/lưu trữ. có chấp nhận được không?

Threat model: các bên tin cậy và không tin cậy

Nói dễ hiểu: đừng để bên giữ "ổ khóa" (cloud) cũng là bên biết luôn nội dung bên trong.

KHÔNG TIN CẬY - Cloud Storage

- Honest-but-curious: tuân thủ đúng giao thức nhưng có thể cố đọc hoặc suy luận nội dung dữ liệu đã lưu.
- Rủi ro nội bộ: admin lạm quyền, thông tin đăng nhập bị lộ, hoặc bị cấu hình sai.
- Có toàn quyền truy cập vật lý lên ổ đĩa và bản sao lưu của cơ sở dữ liệu.

TIN CẬY - Chủ sở hữu & Key Authority

- Chủ sở hữu dữ liệu: định nghĩa Access Policy và giữ dữ liệu gốc trước khi mã hóa.
- Key Authority: cấp và thu hồi khóa thuộc tính, được giả định trung thực và luôn sẵn sàng.
- Không tham gia lưu trữ hay xử lý truy vấn dữ liệu hằng ngày trên cloud.

PHẠM VI BẢO VỆ (THEO CIA)

Confidentiality: CÓ — CP-ABE đảm bảo chỉ đúng thuộc tính mới đọc được.

Integrity & Availability: KHÔNG - cần cơ chế khác để chống sửa/xóa dữ liệu hoặc từ chối dịch vụ; ngoài phạm vi đồ án.

NGOÀI PHẠM VI

- Sự thông đồng (collusion) giữa nhiều user hợp lệ kết hợp khóa thuộc tính của họ.
- Trường hợp Key Authority bị xâm nhập - nằm ngoài phạm vi phân tích của đồ án.
- Tìm kiếm trên dữ liệu mã hóa.

Use case giả định: bệnh viện muốn outsource hồ sơ bệnh nhân lên cloud

Nói dễ hiểu: mỗi người chỉ có "chìa khóa" mở đúng phần hồ sơ liên quan đến công việc của mình — không hơn.



Bác sĩ

THUỘC TÍNH (ATTRIBUTES)

Khoa: Tim mạch
Vai trò: Bác sĩ

GIẢI MÃ (DECRYPT) →

Toàn bộ hồ sơ bệnh án



Y tá

THUỘC TÍNH (ATTRIBUTES)

Khoa: Tim mạch
Vai trò: Y tá

GIẢI MÃ (DECRYPT) →

Chỉ sinh hiệu & thuốc



Nhân viên thu ngân

THUỘC TÍNH (ATTRIBUTES)

Bộ phận: Tài chính
Vai trò: Thu ngân

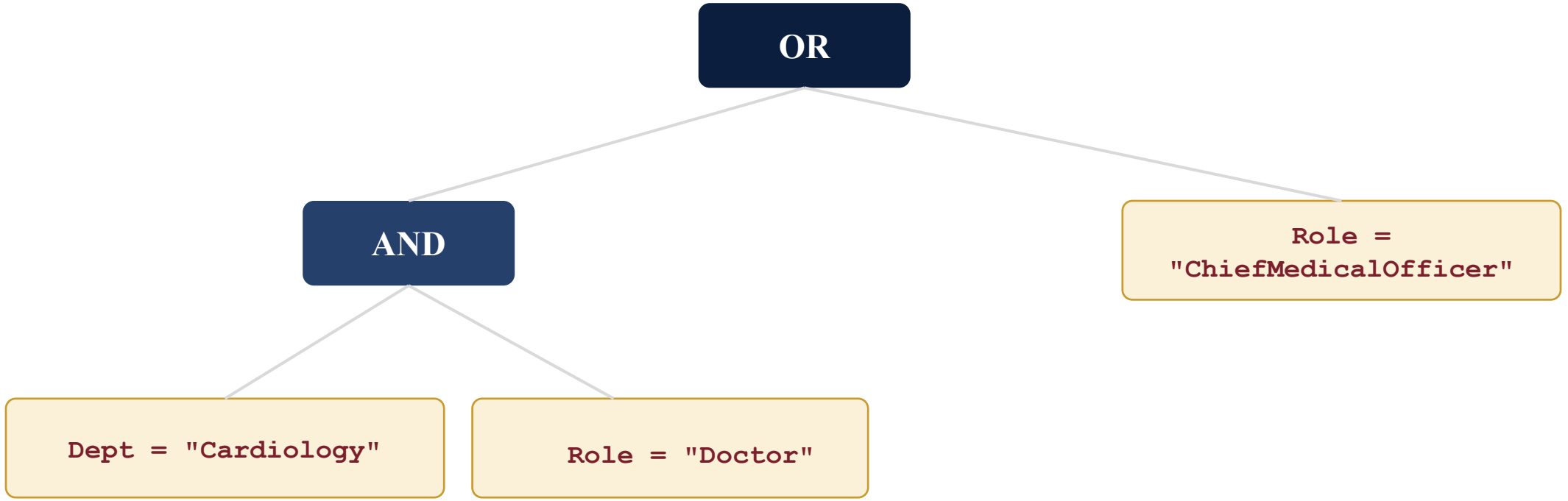
GIẢI MÃ (DECRYPT) →

Chỉ thông tin bảo hiểm & thanh toán

`Access Policy cho bản ghi bệnh án đầy đủ: (Dept="Cardiology" AND Role="Doctor") OR Role="ChiefMedicalOfficer"`

Access Structure (cấu trúc truy cập): biểu diễn Access Policy dạng cây

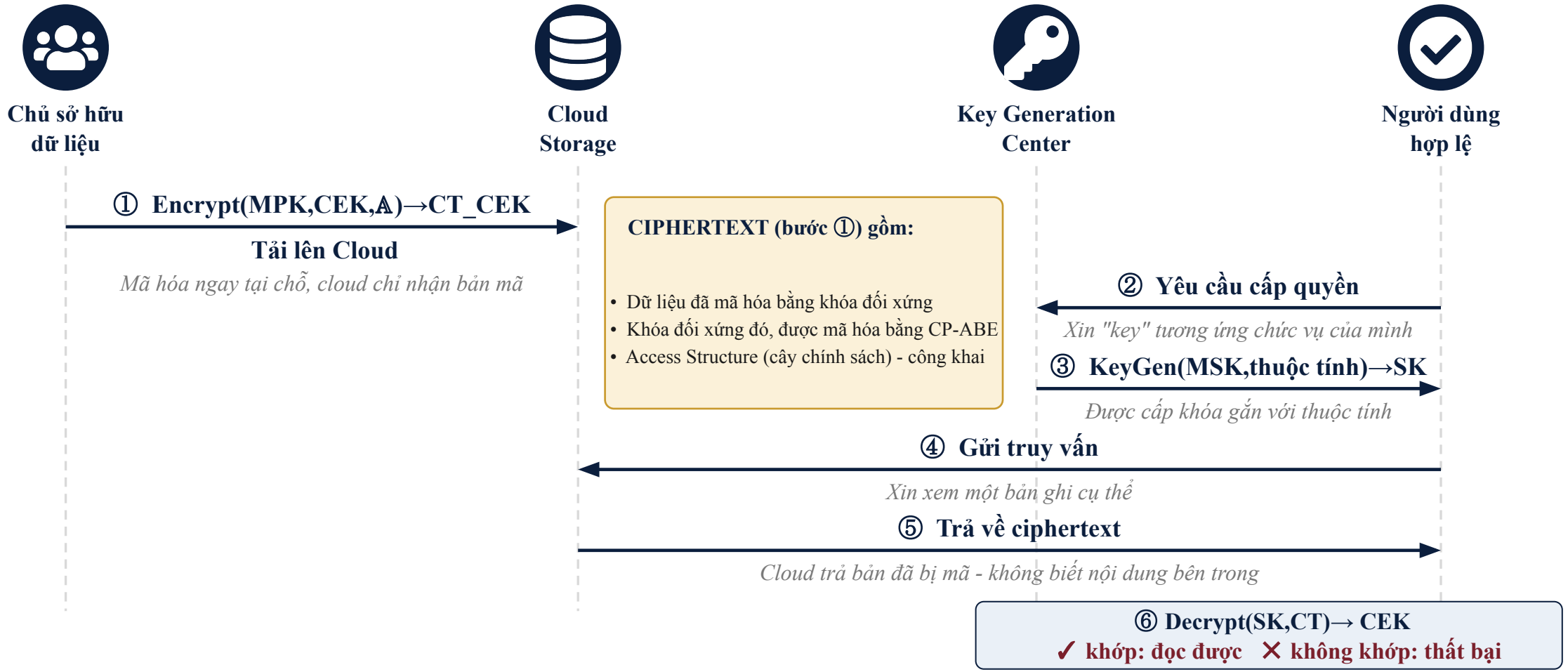
CP-ABE hiện thực một Access Policy thành một cây: cổng AND/OR ở các nút trong, thuộc tính ở các nút lá — khớp với ví dụ ở slide trước. Nói dễ hiểu: giống ổ khóa số nhiều tổ hợp, chỉ ai có đúng tổ hợp (thuộc tính) mới mở được.



Bác sĩ `{Dept=Cardiology, Role=Doctor}`
AND: ✓ và ✓ → TRUE → OR → TRUE
✓ GIẢI MÃ ĐƯỢC

Y tá `{Dept=Cardiology, Role=Nurse}`
AND: ✓ và ✕ → FALSE, Role ≠ ChiefMedicalOfficer
✕ KHÔNG GIẢI MÃ ĐƯỢC

Kiến trúc tổng quan và luồng xử lý giữa các thành phần



Ngay cả khi host bị xâm nhập hoàn toàn, kẻ tấn công cũng chỉ có được bản mã ở bước ① và ⑤ - không bao giờ thấy dữ liệu gốc.

Kiến trúc triển khai của hệ thống đề xuất



Từng nội dung nhóm sẽ triển khai

1 Định nghĩa Access Policy

Data Owner xác định chính sách truy cập theo thuộc tính (Dept, Role...) cho từng trường dữ liệu nhạy cảm cần bảo vệ.

2 Encrypt() - Mã hóa cục bộ

Dữ liệu được mã hóa bằng CP-ABE, CEK ngay tại tổ chức, trước khi rời biên giới tin cậy - cloud không bao giờ thấy plaintext.

3 Lưu trữ trên Cloud

Ciphertext được tải lên Cloud Storage, bên host chỉ đóng vai trò lưu trữ thụ động.

4 Setup() & KeyGen()

Key Generation Center khởi tạo một master key duy nhất cho toàn bộ hệ thống. master key được dùng để tạo secret key dựa theo thuộc tính đối tượng cần cấp

5 Truy vấn & Decrypt()

User gửi truy vấn tới Cloud, nhận ciphertext, rồi tự chạy Decrypt() cục bộ bằng Secret Key của mình - Cloud không tham gia bước giải mã.

6 Kết quả & Thu hồi khóa

Giải mã thành công khi Secret Key cá nhân khớp.
Thu hồi các key đã cung cấp cho người dùng theo chính sách.

Bài toán được giải quyết: quyền truy cập không còn phụ thuộc vào việc tin tưởng nhà cung cấp cloud. Dữ liệu trên cloud không thể đọc trực tiếp kể cả khi host bị xâm nhập hoàn toàn.

Cơ chế thu hồi thuộc tính khi người dùng mất quyền truy cập

CP-ABE gốc chưa cung cấp cơ chế thu hồi khóa

Attribute Versioning

Mỗi thuộc tính gắn số phiên bản (v1, v2...). Khi thu hồi, tăng version và cấp lại khóa mới cho các user còn hợp lệ.

Đơn giản, cần cấp lại khóa hàng loạt

Lazy Re-encryption

Mã hóa lại một bản ghi khi có truy vấn tiếp theo tới dữ liệu đó.

Giảm chi phí tức thời, độ trễ thu hồi

Time-bound Keys

Secret Key có thời hạn hiệu lực ngắn, user phải xin cấp lại định kỳ - quyền tự hết hạn nếu không gia hạn.

Đơn giản vận hành, có độ trễ thu hồi

Kiểm chứng thiết kế: kịch bản tấn công

Kịch bản A - DBA nội bộ

Hành động: DBA của nhà cung cấp cloud truy vấn trực tiếp dữ liệu trên console quản trị.

Kết quả: Chỉ thấy ciphertext, không có Secret Key để giải mã.

✓ AN TOÀN

Kịch bản B - Vượt quyền nội bộ

Hành động: Y tá cố đọc phần chẩn đoán không thuộc quyền hạn của mình.

Kết quả: Decrypt() thất bại vì thuộc tính không thỏa Access Policy.

✓ AN TOÀN

Kịch bản C - Thu hồi trễ

Hành động: Nhân viên vừa nghỉ việc cố dùng Secret Key cũ để truy cập.

Kết quả: Phụ thuộc cơ chế thu hồi đã chọn, cần đo độ hiệu quả

CẦN ĐÁNH GIÁ THÊM

Tóm tắt đề xuất và hướng phát triển tiếp theo

Tóm tắt: Triển khai mô hình hướng tới việc bảo vệ dữ liệu trên cloud bằng mã hóa CP-ABE để không còn phụ thuộc vào độ tin cậy của bên thứ ba; đồng thời đặt ra các hướng cải tiến tiếp theo về khả năng tìm kiếm, hiệu năng và phân tán quản lý khóa.

HƯỚNG PHÁT TRIỂN TIẾP THEO

Ngắn hạn: Xây PoC mô hình cơ bản.

Dài hạn: Dần cải tiến hạn chế đã biết của mô hình theo một số hạn chế được liệt kê dưới đây.

Hạn chế hiện tại	Kỹ thuật cải tiến (về mặt lý thuyết)
Key Authority là điểm yếu duy nhất (SPOF)	Multi-Authority CP-ABE - nhiều Key Authority độc lập, mỗi bên quản một nhóm thuộc tính.
Khả năng triển khai dữ liệu có cấu trúc	Searchable Encryption (ABSE) trên dữ liệu database.
Thu hồi khóa	Attribute Versioning, Lazy Re-encryption, Time-bound Keys
Chi phí tính toán	Outsourced Decryption - Cloud gánh phần lớn phép toán, trả bản mã đã "gọt nhẹ".



CẢM ƠN THẦY/CÔ VÀ CÁC BẠN ĐÃ LẮNG NGHE

Q & A

MÔ HÌNH KIỂM SOÁT TRUY CẬP CHO OUTSOURCED STORAGE